

POLICIES FOR EMPLOYEE PRODUCTIVITY AND ACTIVITY MONITORING SYSTEMS

Organization: Meridian Trust Financial Group

**Industry Sector: Financial Services (Retail and
Commercial Banking)**

Policy Format: Singular Policy Format

By

Group 31

Suraj Parajuli | Naod Zeleke

Submitted To

Prof. R. Alomari

**MITS 5600G – Security Policies and Risk
Management**

Ontario Tech University

Oshawa, Ontario

June 2026

TABLE OF CONTENTS

TECHNOLOGY SUMMARY	4
Overview of the Technology	4
Security Risks, Threats, Vulnerabilities and Benefits	4
Privacy, Legal, Ethical, and Regulatory Concerns	4
Business Impact and Operational Consideration	5
Real world Incidents and Case Studies	6
POLICY ONE: EMPLOYEE NOTICE AND CONSENT FOR WORKPLACE MONITORING.....	7
1.1 Policy Introduction.....	7
1.1.1 Purpose.....	7
1.1.2 Scope	7
1.1.3 Definitions	7
1.2 Policy Document.....	8
1.2.1 Policy Rules and Requirements	8
1.2.2 Roles and Responsibilities.....	9
1.2.3 Compliance and Enforcement.....	9
POLICY TWO: DATA COLLECTION SCOPE AND CLASSIFICATION FOR EMPLOYEE MONITORING.....	10
2.1 Policy Introduction.....	10
2.1.1 Purpose.....	10
2.1.2 Scope	10
2.1.3 Definitions	10
2.2 Policy Document.....	11
2.2.1 Policy Rules and Requirements	11
2.2.2 Roles and Responsibilities.....	12
2.2.3 Compliance and Enforcement.....	12
POLICY THREE: MANAGER AND ADMINISTRATIVE ACCESS CONTROL FOR MONITORING DATA.....	13
3.1 Policy Introduction.....	13
3.1.1 Purpose.....	13
3.1.2 Scope	13
3.1.3 Definitions	13

3.2	Policy Document.....	14
3.2.1	Policy Rules and Requirements.....	14
3.2.2	Roles and Responsibilities.....	15
3.2.3	Compliance and Enforcement.....	15
POLICY FOUR: MONITORING DATA RETENTION, DELETION, AND LEGAL HOLD		16
4.1	Policy Introduction.....	16
4.1.1	Purpose.....	16
4.1.2	Scope	16
4.1.3	Definitions.....	16
4.2	Policy Document.....	17
4.2.1	Policy Rules and Requirements.....	17
4.2.2	Roles and Responsibilities.....	18
4.2.3	Compliance and Enforcement.....	18
REFERENCES		19

TECHNOLOGY SUMMARY

Overview of the Technology

Employee Productivity and Activity Monitoring (EPAM) System is a software platform that observes, records and analyzes the employee work behavior and the activity they perform digitally. Meridian Trust Financial Group is a retail and commercial bank and EPAM tool supports remote and hybrid branch, contact center, underwriting and support staff serving all traditional workforce management and also looks out for insider-threat and acts as fraud-detection control layer (Ajunwa et al., 2017).

EPAM system relies on multiple lightweight endpoints that capture application usage, idle time, network telemetry, screenshots (where applicable) and Keystrokes and then transmits this collected data over encrypted channel to a centralized analytics console (Ball, 2021). The system runs with elevated privileges which ensures persistent access to the system-level-activity. This helps administrative dashboards be configured by security and HR personnel based on the collected data, at what frequency and for which employee groups with role-based permissions that governs who may view the final reports (Aloisi & De Stefano, 2022).

At Meridian Trust Financial Group, the EPAM platform is integrated with the broader security information and event management (SIEM) environment. It helps monitor any unusual employee behavior and helps correlate with core banking access logs, payments and wire transfer approvals, and even customer account modification staying consistent with OSFI Guideline B-13 expectations for technology and cyber risk-governance (OSFI, 2022).

Security Risks, Threats, Vulnerabilities and Benefits

Employee Productivity and Activity Monitoring System (EPAM) collects various information and aggregates these sensitive behavioral and credential data. These information are high-value targets for any attackers such as eternal and malicious insider agent. The key risks include data exfiltration from the centralized telemetry repositories that could capture account and transaction fragments, endpoints that could get compromised which is a pivot point into banking networks, credential harvesting that could be achieved through captured screenshots and keystrokes and some third-party vendor risk, since EPAM deployment relies on SAAS providers whose security posture affects the company (NIST, 2020).

On the positive side, EPAM data helps strengthen insider-fraud detection, it supports as OSFI and FINTRAC audit evidence. It helps identify account takeover and help analyze patterns that could identify embezzlement by correlating unusual behavior. This makes EPAM meaningful even if it is double-edged.

Privacy, Legal, Ethical, and Regulatory Concerns

Meridian Trust, as a federally regulated financial institution, operates under an unusually layered set of rules around employee monitoring. Federally, PIPEDA requires that monitoring be transparent and proportionate to its purpose (Office of the Privacy Commissioner of Canada, 2023). Provincially, Ontario's Working for Workers Act adds its own disclosure requirement on top of that (Legislative Assembly of Ontario, 2022). And because Meridian Trust is a bank, OSFI Guideline B-13 layers on a third expectation: that monitoring of privileged user activity be proportionate to the institution's actual risk profile, not just compliant on paper (OSFI, 2022).

There's also a fourth wrinkle worth noting , wherever EPAM telemetry overlaps with payment-card data, like contact center staff handling card-present disputes, the institution has to make sure its monitoring setup doesn't accidentally run afoul of PCI DSS rules around how cardholder data gets handled on monitored devices (PCI Security Standards Council, 2022).

Beyond the legal side, there's a real ethical question here too. EPAM systems touch on employee dignity, autonomy, and psychological safety, and those concerns only get sharper in a banking environment that's already under heavy regulatory scrutiny and compliance pressure. The research on this is fairly consistent: constant monitoring tends to raise stress, erode trust, and can actually get in the way of the kind of judgment calls loan officers and relationship managers are supposed to be making (Ravid et al., 2020). It gets more complicated still when you factor in behavioral biometrics, things like keystroke patterns or mouse movement, since collecting that kind of data raises its own privacy questions. Even when employee-level data is supposedly anonymized, there's a real risk that cross-referencing it with other monitoring data could end up re-identifying customers, not just employees.

On the compliance side, FINTRAC's anti-money laundering and counter-terrorism financing rules require Meridian Trust to keep records showing that employees handling suspicious transaction reports have proper access controls and audit trails in place. This is actually one area where EPAM data earns its keep , it can serve as solid evidence of compliance, as long as how it's collected and retained stays proportionate and lawful.

Business Impact and Operational Consideration

The implementation of an Employee Productivity and Activity Monitoring (EPAM) system provides operational, security, and compliance benefits for Meridian Trust Financial Group. Monitoring data can help identify inefficiencies in loan-processing and customer-service operations, support performance management, detect unusual access patterns associated with account compromise or insider fraud, and provide evidence during internal audits and OSFI examinations (Aloisi & De Stefano, 2022).

EPAM data also supports incident investigations by providing forensic evidence for data-loss events, unauthorized access, fraud, and policy violations, while assisting with regulatory reporting obligations.

However, excessive monitoring may reduce employee trust, engagement, and retention, particularly among skilled professionals such as underwriters, relationship managers, and cybersecurity personnel (Ball, 2021). Organizations may also face reputational risks if monitoring practices are perceived as intrusive.

Because EPAM systems collect large volumes of sensitive data, Meridian Trust must enforce strong governance through access controls, encryption, retention schedules, secure deletion procedures, and segregated storage environments. Failure to manage monitoring data appropriately may result in privacy breaches, regulatory findings, and reputational harm.

Real world Incidents and Case Studies

A well-known example of the risks associated with Employee Productivity and Activity Monitoring (EPAM) systems occurred in 2025 when WorkComposer, a workplace monitoring platform used by more than 200,000 employees across thousands of organizations, exposed over 21 million screenshots due to an improperly secured Amazon S3 storage bucket (Okunytė, 2025). The platform was designed to monitor employee productivity by recording activity and capturing periodic screenshots of employee screens. As a result of the exposure, sensitive information became publicly accessible, including internal emails, workplace communications, login screens, credentials, API keys, and confidential business documents.

The WorkComposer incident was not an isolated case. A separate Cybernews investigation reported that WebWork, another employee-monitoring platform, exposed more than 13 million screenshots containing emails, passwords, and other sensitive information from employee work environments. These incidents demonstrate how monitoring systems can create significant privacy and security risks when appropriate safeguards are not implemented.

For Meridian Trust Financial Group, these events provide an important lesson regarding the deployment and management of EPAM technologies. The WorkComposer breach was not caused by a sophisticated cyberattack; rather, it resulted from a basic storage configuration error. This type of failure highlights the importance of implementing strong security controls such as encryption, restricted storage access, retention limits, and secure deletion procedures. Within a financial institution, the consequences of a similar incident could be far more severe. Exposed screenshots could reveal employee access to core banking systems, customer account information, payment-processing interfaces, or wire-transfer approval screens, potentially resulting in reportable privacy breaches under PIPEDA and regulatory scrutiny from OSFI.

These incidents also help explain why workplace monitoring has received increased regulatory attention in Ontario. Since October 11, 2022, Ontario's Working for Workers Act, 2022 has required employers with 25 or more employees to maintain a written policy describing whether employees are electronically monitored, how monitoring occurs, and the purpose of the monitoring (Ontario, 2022). While the legislation does not prohibit employee monitoring, it promotes transparency and accountability. Similarly, OSFI Guideline B-13 encourages financial institutions to ensure that monitoring controls are properly governed, documented, and proportionate to organizational risks (OSFI, 2022).

Taken together, these incidents demonstrate that employee-monitoring technologies must be supported by clear policies, strong technical safeguards, and effective governance processes. Without these controls, organizations risk exposing sensitive information, violating privacy obligations, and damaging employee trust.

POLICY ONE: EMPLOYEE NOTICE AND CONSENT FOR WORKPLACE MONITORING

1.1 Policy Introduction

Policy Title	Employee Notice and Consent for Workplace Monitoring
Policy Number	EPAM-001
Version	1.0
Effective Date	June 1, 2026
Review Date	June 1, 2027
Policy Owner	Chief Information Security Officer (CISO)
Approved By	Executive Risk Committee

1.1.1 Purpose

The purpose of this policy is to make sure that all each and every individuals that are subject to electronic monitoring preformed by **Meridian Trust Financial Group** must receive clear, timely and proper notice of the policy. It should also specify the nature, purpose and extent of such monitoring in compliance with Ontario's Working of Workers Act (Bill 88, 2022), PIPEDA and the technology risk-governance expectation set in OSFI Guideline B-13. As a federally regulated organization, Meridian Trust Financial Group is committed to conducting monitoring activities in a transparent manner that balances legitimate operations checking and fraud-detection through monitoring.

1.1.2 Scope

The following policy applies to all Meridian Trust Financial Group's employees, contractors and third-party workers under contract which includes branch staffs, agents, underwriters, treasury operations personnel's and support staffs who use the organization issued or any personal devices to conduct banking business in remote or hybrid work environment through Employee Productivity and Activity Monitoring (EPAM) System.

1.1.3 Definitions

Terms	Definition
Electronic Monitoring	Act of collection and analysis of employee activity through digital means such as Keystrokes, screenshots, logs, metadata and location.
EPAM System	Meridian Trust Financial Group's monitoring platform that is used for monitoring.
Covered Device	Any devices that are used to access company data and banking systems, this includes both personal and company issued devices.
Notice	Written communication that is provided describing the existence, scope and purpose of monitoring prior to commencement.
Consent	Documented proof of employee acknowledgement regarding the monitoring scope prior commencement.
Employee	Any Full-time, part-time, contract or temporary worker engaged by this organization in remote or hybrid capacity.

1.2 Policy Document

1.2.1 Policy Rules and Requirements

a. **Mandatory Written Policy**

Meridian Trust Financial Group must provide a written notice regarding the implemented system at following all of the following circumstances, at hire of new employee, within 5 days of any changes in the monitoring scope, if there is deployment of new EPAM module and during annual review and compliance training. The notice must have information regarding the nature and the categories of the data being collected, which platform are they applied to for the purpose of collection, who has the access to those data and how long will the data be stored for.

b. **Content Requirements for the Notice**

The Electronic Monitoring Policy must explicitly state followings:

- It should mention if the monitoring is continuous or is an event-based action that gets triggered when certain conditions meets, it must also inform regarding the frequency of the data being collected including screenshots, keystrokes, logs and network telemetry.
- It must specify if the location data is being collected at real time or not and what mechanism is used to collect it (GPS or WI-FI).
- It should define if the monitoring is only limited to business hour or is extended beyond that.
- If the monitoring is only for the company issued device or applies to any personal devices used to access the company resources as well.

c. **Acknowledgement and Consent**

All employees and personnel who will be using the organization's resources must sign a written contract that acknowledges the notice provided. The acknowledgement must then be stored and retained in their file for the duration of their employment ad 7 years beyond that, this helps the organization to remaining consistent with institutions broader recordkeeping obligations. Digital signatures are accepted through HR platform and any refusal to acknowledge does not justify discipline, but the monitoring will proceed regardless in compliance with the law.

d. **Restriction on Monitoring Scope**

To comply under privacy legislation and OSFI's risk–governance expectations, Meridian Trust Financial Group ensures that,

- The monitoring is only limited to company-issued device or company managed application and network.
- Any audio or video capture via camera and microphone is strictly prohibited.
- Screenshot and keystrokes capture is only limited to business hours and excludes any personal application contents where feasible.
- Monitoring is on hold during breaks and after business hours unless banking system in active use.

e. Special Circumstances and Exceptions

The primary object of Meridian Trust Financial Group to implement EPAM System is to monitor individual specific connection with fraud or security incidents. The notice timeline that needs to be upheld will be suspended in case of investigation against the individual and it applies to the duration of investigation only. Such type of operation must be approved by CISO and HR director and is limited only to active investigation period.

f. Notice Delivery Channels

Meridian Trust Financial Group is to deliver the notice regarding monitoring to its employee and all other related personnel through two of the following channels: the employee or third-party corporate email account, HR service portal and physical through printed materials during an in-person sessions. In case of the any problem regarding the language a, request can be made directly to HR for notice in language of their own choice.

1.2.2 Roles and Responsibilities

- Human Resources personnel (HR) is responsible for distribution the notice regarding monitoring policy to all the employees and third-party user to the company resources and maintain the record of their acknowledgements.
- Chief Information Security Officer (CISO) is responsible for the technical configuration of the Employee Productivity and Activity Monitoring System to ensure that it aligns with the scope define in the policy.
- Privacy Officer is responsible to periodic review of the policy, either annually or if any regulatory changes in OSFI, FINTRAC or the Office of the Privacy Commissioner is observed.
- Branch Manager and Team Managers must direct any question that arise form employee regarding monitoring system to HR or the privacy Officer and must never disclose monitoring data to unauthorized parties.

1.2.3 Compliance and Enforcement

Any non-compliance with this policy and notice requirements by Meridian Trust Financial Group management or HR personnel will result in violation under the Ontario's Working for Workers Act, 2022 and might expose the institution to administrative penalties in case of adverse findings during OSFI examinations.

If any employee concerns are regarding the monitoring activities being exceeded far beyond the scope described in their notice are highly encouraged to report their findings directly to the privacy officer via a confidential reporting channel. Any confirmed monitoring overreach will be treated as a privacy violation and will be subject to remediation and where applicable regulatory notifications.

This policy shall be reviewed annually by the Privacy Officer and CISO and will reflect any changes in the applicable legislation, guidance, organizational structure or EPAM System.

POLICY TWO: DATA COLLECTION SCOPE AND CLASSIFICATION FOR EMPLOYEE MONITORING

2.1 Policy Introduction

Policy Title	Data Collection Scope and Classification for Employee Monitoring
Policy Number	EPAM-002
Version	1.0
Effective Date	June 1, 2026
Review Date	June 1, 2027
Policy Owner	Chief Information Security Officer (CISO)
Approved By	Executive Risk Committee

2.1.1 Purpose

The purpose of this policy is to define the categories of the data that Meridian Trust Financial Group is collecting through its EPAM System, to classify those collected data types according to sensitivity level using institutional enterprise data classification scheme and to establish the base necessary collection principle that is both operationally justifiable and legally permissible. This policy operationalizes the organization's commitment to data minimization according to PIPEDA and reinforces control expected under PCI DSS for any monitored endpoint that consist of cardholder data.

2.1.2 Scope

This policy is applicable to all Meridian Trust Financial Group personnel that are involved in the configuration, administration, access or oversight of the EPAM System as well as those employees and staffs whose activity are subject to monitoring with access to core banking, payments and customer relationship management system. This policy also specifies the limitations on collection of data on each category.

2.1.3 Definitions

Terms	Definition
Data Minimization	Collection of the minimum data that is needed for legitimate purpose.
Keystroke Logging	Automated recording of the individual keys pressed on the keyboard.
Screenshot	Automated capture of the still images of an employee device screen at predefined time intervals or upon triggered events.
Application Log	Event of saving the record of all the software application an employee has opened use or interacted with in a particular time frame.
Network Telemetry	Collection of data that defines the employee's network configuration including IP address, bandwidth usage and domains.
Location	Data describing the location of the devices used to access the company data using GPS or WI-FI association.
Idle time	Period of no user input or activity on the monitored device.
Sensitive Personal Information	Health, Financial, Cardholder or biometric data that needs extended protection.

2.2 Policy Document

2.2.1 Policy Rules and Requirements

a. Authorized Data Categories

Meridian Trust Financial Group is authorized to collect following data's based on the classification and subject to collection limitations:

Data Category	Classifications	Collection Limitations
Application Log	Internal - Restricted	Banking and company application only.
Idle/Active Time	Internal - Restricted	Aggregated, with no continuous real-time feed to manager.
Website/ URL visited	Internal - Restricted	Collected only at a category level and does not log URL and doesn't record personal browsing history.
Screenshot Captures	Confidential	Triggered only by policy violation or fraud-risk flags
Network telemetry	Confidential	Security and fraud detection use only.
Location	Confidential	For attendance confirmation only, no live-time tracking.
Core Banking Access Events	Highly Confidential	System-of-record audit logs only that is correlated and not duplicated.

b. Prohibited Data Collection

The following categories are prohibited for collection through the monitoring system:

- Keystrokes content is strictly prohibited, only volume metrics are permitted.
- Audio recording from device microphone is prohibited
- Video recording device camera for passive surveillance is prohibited.
- Any personal communication performed through personal email or messaging is prohibited.
- Collection of any health, medical and biometric data that is not related to the organization is prohibited.
- Primary Account number, CVV codes and cardholder data must be collected in compliance with PCI DSS data minimization requirements.
- Any data that is generate outside of the Meridian Trust Financial Groups managed application.

c. Data Minimization Requirements

The EPAM System administrator must configure the data collection with compliance with the minimum necessary standard. Any configurations that expand beyond the categories previously stated in Authorized data category (2.2.1.a) should require written approval by both privacy Officer and CISO prior to the deployment of the monitoring. Annual audits should verify that all the active collections module correspond to authorized categories and the results of the audit should be reported to Executive Risk Committee as part of organizations broader technology risk-governance process under OSFI Guideline B-13. Any discrepancy that is identified during the audit must ne remediated within 10 business days.

d. Sensitive Data Handling

In case of the EPAM System accidentally capturing sensitive data such as personal data or cardholder information with screenshots of partial account numbers and fragments of cardholder data or payment data, the following steps shall be taken:

- i. The data must be immediately flagged and quarantined by the administrator
- ii. Privacy Officer and PCI Compliance lead must be informed about the data collection within 24 hours,
- iii. The data must be securely deleted unless it was taken for an active fraud and security investigation,
- iv. The incident must be logged for regulatory reporting assessment.

2.2.2 Roles and Responsibilities

- The CISO is responsible for all the configuration in the EPAM System and must ensure that collection of data aligns with authorized categories.
- The Privacy Officer is responsible for reviewing data classification and is also responsible for approving or declining any expansion request.
- PCI Compliance Lead is responsible regarding assessing incidents involving customer card data exposure.
- System Administrators are responsible for configuration changes and monthly self audits.
- Internal Audit is responsible for annual configuration audit report and should report it to Executive Risk Committee.

2.2.3 Compliance and Enforcement

Any unauthorized data collection that is not listed in the data category in 2.2.1.a or collected against section 2.2.1.b, constitutes serious violation of policy and may result in disciplinary actions and even termination and may trigger regulatory notification obligations to OSFI, the office of Privacy Commissioner, and payment card brands.

Employee who discover unauthorized data collection must report it to the Privacy Officer. The Privacy officer should investigate the incident and if needed and constitutes a reportable breach should report it under 72 hours of notification to the applicable legislation.

POLICY THREE: MANAGER AND ADMINISTRATIVE ACCESS CONTROL FOR MONITORING DATA

3.1 Policy Introduction

Policy Title	Manager and Administrative Access Controls for Monitoring Data
Policy Number	EPAM-003
Version	1.0
Effective Date	June 1, 2026
Review Date	June 1, 2027
Policy Owner	Chief Information Security Officer (CISO)
Approved By	Executive Risk Committee

3.1.1 Purpose

This policy sets out who at Meridian Trust Financial Group can access employee productivity and monitoring data, under what circumstances, and why. The goal is straightforward: access to monitoring data should match actual operational need, be protected from misuse, and stand up to audit scrutiny. That's consistent with what's expected of Meridian Trust under PIPEDA, applicable employment law, and OSFI Guideline B-13's expectations around managing privileged access.

3.1.2 Scope

This policy applies to anyone at Meridian Trust Financial Group who has access to employee monitoring data, whether through the EPAM administrative console or any downstream reporting system. That covers branch and team managers, HR business partners, security analysts, fraud investigation staff, EPAM system administrators, and executive leadership. It doesn't apply to employees viewing their own monitoring data through the self-service employee portal.

3.1.3 Definitions

Terms	Definition
Role-Based Access Control (RBAC)	A system where access permissions are tied to someone's job role, rather than being set individually for each person.
EPAM Administrative Console	The management interface for the employee monitoring platform, where configurations, reports, and raw telemetry data can be accessed.
Need-to-Know Basis	The principle that someone only gets access to sensitive information if their job actually requires it.
Privileged Access	Access that goes beyond what a standard employee gets , for example, the ability to view individual monitoring records, raw telemetry, or screenshot captures
Access Review	A periodic check where existing access rights get evaluated, confirmed, or revoked if they're no longer needed.
Audit Log	An automatic, tamper-proof record of what users do in a system , logins, data queries, configuration changes, exports, and so on.
Fraud Investigation Unit	Meridian Trust's internal team responsible for investigating suspected employee fraud, account-takeover schemes, and policy violations involving customer financial data

3.2 Policy Document

3.2.1 Policy Rules and Requirements

a. Access Tiers and Permitted Actions

Access to EPAM monitoring data shall be organized into four access tiers, each with defined permitted actions:

Tier	Role	Permitted Access	Restrictions
Tier 1	Branch/Team Manager	Aggregated team productivity dashboards only	No individual raw telemetry; no screenshots
Tier 2	HR Business Partner	Individual-level productivity summaries for performance cases	Requires documented HR case number
Tier 3	Security Analyst / Fraud Investigator	Raw telemetry and screenshots for security or fraud investigations	Requires case ticket; CISO and Fraud Unit Lead notification
Tier 4	EPAM Administrator / CISO	Full system access including configuration	Dual-authorization required for bulk exports

b. Access Request and Approval Process

Anyone requiring access above Tier 1 must submit a formal request through Meridian Trust's IT service management system. The request must clearly state the business justification, the scope of access required, and the expected duration of access. Approval must be obtained from the employee's direct manager and either the HR Director (Tier 2 access) or the CISO (Tier 3 and Tier 4 access). In accordance with OSFI expectations for privileged access management, Tier 3 and Tier 4 access rights must be reviewed and recertified every six months. Temporary elevated access granted for fraud or security investigations must be removed within five business days after the investigation is closed.

c. Restrictions on Manager Use of Monitoring Data

Branch and team managers with Tier 1 access are limited to aggregated productivity information and must not access or attempt to obtain individual-level monitoring data without proper authorization. Specifically, managers shall not:

- Share dashboard data with individuals outside their direct area of responsibility;
- Use productivity metrics as the sole basis for employee performance evaluations without considering additional evidence from the organization's performance management process;
- Request or obtain individual-level telemetry through informal or unauthorized channels;
- Export, download, or store monitoring reports on personal or unmanaged devices; or
- Direct EPAM administrators to conduct monitoring of a specific employee without prior authorization from the CISO and notification to Human Resources.

These restrictions are intended to ensure that monitoring data is used appropriately, consistently, and in accordance with organizational policies, privacy obligations, and regulatory requirements.

d. Audit Logging and Monitoring of Administrator Activity

All activities performed within the EPAM administrative console must be recorded in tamper-evident audit logs and retained for a minimum of seven years to satisfy regulatory recordkeeping requirements. Each log entry must capture the user identity, date and time of access, action performed, affected data, and source IP address. Internal Audit shall review administrator activity on a quarterly basis and report significant findings to the Executive Risk Committee. Any unusual activity, including bulk data exports, after-hours access, or access to employee records without an active business justification, must be reported to the CISO within 48 hours for review.

e. Prohibition on Personal Use of Monitoring Data

Monitoring data shall be used only for legitimate business purposes, including workforce productivity management, security and fraud investigations, HR performance reviews, and regulatory or legal compliance activities, including OSFI, FINTRAC, and PCI DSS examinations. Accessing or using monitoring data for personal reasons, curiosity, harassment, discrimination, or personal advantage is strictly prohibited and constitutes a violation of this policy and applicable privacy legislation.

3.2.2 Roles and Responsibilities

The CISO is responsible for maintaining this policy, managing access tiers, and approving Tier 3 and Tier 4 access requests. The HR Director approves Tier 2 access and ensures that monitoring data is used in accordance with employment legislation and organizational policies. The Fraud Investigation Unit Lead authorizes Tier 3 access for fraud-related investigations. EPAM administrators implement access controls, maintain audit logs, and support ongoing system oversight. Internal Audit reviews administrator activity quarterly and reports significant findings to the Executive Risk Committee. Branch and team managers are responsible for complying with their assigned access levels and reporting any unauthorized access requests.

3.2.3 Compliance and Enforcement

Any violation of this policy, including unauthorized access attempts, misuse of monitoring data, or failure to follow approved access procedures, will result in the immediate suspension of EPAM access pending investigation and may lead to disciplinary action, up to and including termination. Violations involving harassment, discrimination, fraud, or other unlawful activities may be referred to law enforcement and, where required, reported to OSFI as a significant incident. The CISO shall review this policy annually and update it as necessary to reflect changes in regulatory requirements, organizational structure, or EPAM system capabilities.

POLICY FOUR: MONITORING DATA RETENTION, DELETION, AND LEGAL HOLD

4.1 Policy Introduction

Policy Title	Monitoring Data Retention, Deletion, and Legal Hold
Policy Number	EPAM-004
Version	1.0
Effective Date	June 1, 2026
Review Date	June 1, 2027
Policy Owner	Chief Information Security Officer (CISO)
Approved By	Executive Risk Committee

4.1.1 Purpose

The purpose of this policy is to establish clear retention, deletion, and legal hold requirements for all monitoring data collected through Meridian Trust's EPAM system. The policy ensures that monitoring data is retained only for approved periods, securely deleted when no longer required, and preserved when necessary to support legal proceedings, regulatory examinations, or internal investigations, including those involving OSFI or FINTRAC.

4.1.2 Scope

This policy applies to all monitoring data collected through Meridian Trust's EPAM system, including application usage logs, productivity metrics, screenshot captures, network telemetry, location data, and related records. It applies to all storage environments, including cloud platforms, on-premises systems, backup repositories, and archived data. The policy also establishes requirements for how EPAM administrators, IT Operations, Legal Counsel, Compliance, and the Privacy Officer manage, retain, access, and dispose of monitoring data.

4.1.3 Definitions

Terms	Definition
Retention Period	The length of time a specific category of data is authorized to be retained after collection.
Deletion	The permanent and irreversible removal of data from all storage locations, including primary systems, backups, and disaster recovery repositories.
Legal Hold	A formal directive that suspends scheduled deletion when data is required for litigation, regulatory investigations, or internal disciplinary proceedings.
Personally Identifiable Information (PII)	Any information that can identify an individual, including names, employee IDs, device identifiers, and IP addresses contained in monitoring records.
Regulatory Examination Record	Documentation retained to demonstrate compliance during reviews conducted by OSFI, FINTRAC, or other regulatory authorities.

4.2 Policy Document

4.2.1 Policy Rules and Requirements

a. Retention Schedule by Data Category

Meridian Trust retains monitoring data according to the schedule below, balancing operational requirements, regulatory obligations, and the principle of proportionality.

Data Category	Retention	Storage Tier	Deletion Method	Basis
Application usage logs	90 days	Active storage	Automated purge	PIPEDA
Aggregated productivity metrics	2 years	Archive	Automated purge w/ audit log	Employment Standards Act
Screenshot captures	30 days	Restricted active storage	Cryptographic erasure + log	PIPEDA
Network telemetry	6 months	Security data lake	Automated purge	OSFI
Location data	30 days	Active storage	Automated purge	PIPEDA
Fraud/security investigation exports	Matter + 7 years	Legal hold archive	Manual deletion by Legal	PIPEDA
Regulatory examination records	7 years	Compliance archive	Manual review/deletion	OSFI/FINTRAC

b. Automated Deletion Enforcement

Meridian Trust implements automated deletion controls within the EPAM platform and all connected storage systems to enforce the retention schedule defined in Section 4.1.3 Deletion is permanent and applies to primary storage, backup and disaster recovery copies, cloud-based redundant storage, and offline archives. EPAM administrators must verify monthly that deletion processes are functioning correctly and document the results. Any failure must be reported to the CISO within 24 hours and remediated within five business days. Significant failures shall be escalated to the Executive Risk Committee in accordance with OSFI Guideline B-13 incident-management requirements.

c. Legal Hold Process

When monitoring data may be required for litigation, an OSFI or FINTRAC examination, or an internal disciplinary matter, Legal Counsel, the CISO, Compliance, or an authorized HR representative may initiate a legal hold. Legal Counsel must issue a written hold order identifying the affected employee(s), relevant data categories, and expected duration of the hold. Within 24 hours, the EPAM administrator must suspend automated deletion and transfer the data to the legal hold archive. All holds must be recorded in the Legal Hold Register, including the hold ID, date, scope, and designated legal contact. Legal Counsel shall review each hold every 90 days and remove it once the matter has been resolved.

Access to held data is restricted to Legal Counsel, the CISO, Compliance, and authorized EPAM administrators. All held data must remain encrypted and may only be used for the purpose for which the hold was issued.

d. Employee Departure and Data Deletion

Upon an employee's resignation, termination, or contract expiry, active device monitoring shall cease on the individual's final day of employment. Monitoring data retained for 90 days or less must be deleted within 30 days unless subject to a legal hold. Performance-benchmarking metrics must be anonymized within 90 days. HR shall notify the EPAM administrator within 24 hours of the employee's departure, with priority given to individuals who had access to payment systems, customer accounts, or other sensitive banking resources.

e. Employee Access to Own Data

Under PIPEDA, employees may submit a request to the Privacy Officer to access their monitoring data. Meridian Trust will respond within 30 days. Access is limited to data that remains within its approved retention period and will be appropriately redacted to protect the privacy of other employees, customer financial information, and confidential fraud or security investigation records.

4.2.2 Roles and Responsibilities

Legal Counsel is responsible for issuing and removing legal holds and maintaining the Legal Hold Register. Compliance manages regulatory examination records and serves as the primary liaison with OSFI and FINTRAC. The Privacy Officer oversees compliance with retention requirements and handles employee access requests. EPAM administrators implement automated deletion controls and execute legal hold instructions. The CISO reviews monthly deletion-verification reports and escalates significant issues to the Executive Risk Committee. IT Operations ensures that backup and archive retention practices remain aligned with the approved retention schedule.

4.2.3 Compliance and Enforcement

Failure to delete monitoring data in accordance with the approved retention schedule may constitute unauthorized data retention and could result in violations of PIPEDA, applicable privacy legislation, and regulatory expectations. Deliberately bypassing automated deletion controls without an approved legal hold is considered a serious policy violation and may result in disciplinary action. The Privacy Officer, Compliance, and Legal Counsel shall review this policy annually and update it as necessary to reflect changes in legislation, regulatory guidance, legal hold requirements, or EPAM system capabilities that affect data retention and storage practices.

REFERENCES

1. Ajunwa, I., Crawford, K., & Schultz, J. (2017). *Limitless worker surveillance*. Berkeley Law. <https://lawcat.berkeley.edu/record/1127979?ln=en&v=pdf>
2. Ball, K. (2022). Surveillance in the Workplace: Past, Present, and Future. *Surveillance & Society*, 20(4), 455–461. <https://doi.org/10.24908/ss.v20i4.15805>
3. Joint Task Force. (2020). Security and Privacy Controls for Information Systems and Organizations. *Security and Privacy Controls for Information Systems and Organizations*, 5(5). <https://doi.org/10.6028/nist.sp.800-53r5>
4. Office of The Privacy Commissioner of Canada. (2019). *Privacy in the Workplace - Office of the Privacy Commissioner of Canada*. Priv.gc.ca. https://www.priv.gc.ca/en/privacy-topics/employers-and-employees/02_05_d_17/
5. Legislative Assembly of Ontario. (2022). *Bill 88, Working for Workers Act, 2022*. S.O. 2022, c. 7. <https://www.ola.org/en/legislative-business/bills/parliament-42/session-2/bill-88>
6. Office of the Superintendent of Financial Institutions. (2022). *Technology and cyber risk management* (Guideline B-13). Government of Canada. <https://www.osfi-bsif.gc.ca/en/guidance/guidance-library/technology-cyber-risk-management>
7. Okunyté, P. (2025, April 23). Employee monitoring app leaks 21 million screenshots in real time. Cybernews. <https://cybernews.com/security/employee-monitoring-app-leaks-millions-screenshots/>